

TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN
KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO ĐỒ ÁN
TÌM HIỂU VÀ TRIỂN KHAI CHỨNG
CHỈ SỐ X.509

Môn học: Mã hóa ứng dụng

GVHD: Lương Vĩ Minh

Lớp: 23_22

Thông tin nhóm

23120288	Nguyễn Lê Anh Kiệt
23120332	Nguyễn Trọng Phúc
23120340	Phạm Minh Quân
23120273	Nguyễn Gia Huy

Thành phố Hồ Chí Minh, tháng 5/2026

Mục lục

1	Mở đầu	1
1.1	Mục tiêu đồ án	1
1.2	Phạm vi nghiên cứu	1
2	Cơ sở lý thuyết	1
2.1	Mật mã khóa công khai	1
2.2	Hàm băm mật mã	2
2.3	Chữ ký số	2
3	Tổng quan về X.509	2
3.1	Vai trò của chứng chỉ X.509	3
3.2	Các chủ thể trong PKI	3
4	Cấu trúc chứng chỉ X.509 v3	3
4.1	Các trường cơ bản	3
4.2	Các extension quan trọng	4
4.2.1	Basic Constraints	4
4.2.2	Key Usage	4
4.2.3	Extended Key Usage	4
4.2.4	Subject Alternative Name	5
5	Hạ tầng khóa công khai PKI	5
5.1	Chuỗi tin cậy	5
5.2	Quy trình cấp chứng chỉ	5
5.3	Thu hồi chứng chỉ	6
6	X.509 trong giao thức TLS/HTTPS	6
7	Thực nghiệm với OpenSSL	7
7.1	Tạo khóa riêng cho Root CA	7
7.2	Tạo chứng chỉ tự ký cho Root CA	7
7.3	Tạo khóa riêng cho máy chủ	7
7.4	Tạo file cấu hình SAN	7
7.5	Tạo CSR cho máy chủ	8
7.6	Ký chứng chỉ máy chủ bằng Root CA	8
7.7	Kiểm tra nội dung chứng chỉ	8
7.8	Kiểm tra chuỗi tin cậy	8

8 Phân tích bảo mật	9
8.1 Rủi ro thường gặp	9
8.2 Nguyên tắc triển khai an toàn	9
9 Ứng dụng thực tế	10
9.1 HTTPS	10
9.2 VPN và mạng nội bộ	10
9.3 Chữ ký số và ký mã nguồn	10
9.4 Thiết bị IoT	10
10 So sánh CRL và OCSP	10
11 Hướng dẫn chạy hệ thống và video demo	11
11.1 Chuẩn bị môi trường	11
11.2 Chạy ứng dụng chính	11
11.3 Tài khoản đăng nhập và luồng kiểm thử nhanh	11
11.4 Kiểm tra bằng test suite	12
11.5 Link video demo	12
12 Kết quả đạt được	12
13 Hạn chế và hướng phát triển	13
14 Kết luận	13
Tài liệu tham khảo	14

1. Mở đầu

Trong các hệ thống thông tin hiện đại, nhu cầu xác thực danh tính, bảo vệ tính toàn vẹn dữ liệu và thiết lập kênh truyền bí mật là yêu cầu nền tảng. Khi người dùng truy cập một website qua HTTPS, ký tài liệu điện tử, xác thực máy chủ nội bộ hoặc triển khai VPN, hệ thống đều cần một cơ chế đáng tin cậy để trả lời câu hỏi: khóa công khai này có thật sự thuộc về chủ thể đang giao tiếp hay không?

Chuẩn X.509 ra đời để giải quyết bài toán đó thông qua chứng chỉ số. Chứng chỉ X.509 liên kết danh tính của một chủ thể với khóa công khai của chủ thể đó, đồng thời được ký bởi một tổ chức chứng thực có thẩm quyền. Nhờ vậy, các bên giao tiếp có thể dựa vào chuỗi tin cậy để xác thực lẫn nhau mà không cần trao đổi khóa bí mật từ trước.

1.1. Mục tiêu đề án

Đề án tập trung vào các mục tiêu chính sau:

- Trình bày cơ sở lý thuyết của chứng chỉ số X.509 và hạ tầng khóa công khai PKI.
- Phân tích cấu trúc chứng chỉ X.509 phiên bản 3.
- Mô tả quy trình cấp phát, kiểm tra, sử dụng và thu hồi chứng chỉ.
- Thực hiện minh họa bằng công cụ OpenSSL: tạo CA, tạo chứng chỉ máy chủ, ký chứng chỉ và kiểm tra chuỗi tin cậy.
- Đánh giá rủi ro bảo mật và đề xuất biện pháp triển khai an toàn.

1.2. Phạm vi nghiên cứu

Báo cáo tập trung vào chứng chỉ X.509 trong bối cảnh HTTPS/TLS và PKI doanh nghiệp. Các nội dung như chứng chỉ cho email S/MIME, chữ ký mã nguồn hoặc định danh thiết bị IoT được đề cập ở mức liên hệ ứng dụng.

2. Cơ sở lý thuyết

2.1. Mật mã khóa công khai

Mật mã khóa công khai sử dụng một cặp khóa gồm khóa riêng và khóa công khai. Khóa riêng phải được giữ bí mật tuyệt đối, còn khóa công khai có thể phân phối rộng rãi. Hai ứng dụng quan trọng của cơ chế này là:

- **Mã hóa:** bên gửi dùng khóa công khai của bên nhận để mã hóa dữ liệu, chỉ bên nhận có khóa riêng tương ứng mới giải mã được.
- **Chữ ký số:** bên ký dùng khóa riêng để tạo chữ ký, bên kiểm tra dùng khóa công khai để xác minh chữ ký.

Tuy nhiên, nếu chỉ có khóa công khai thì chưa đủ. Một kẻ tấn công có thể thay thế khóa công khai thật bằng khóa của mình. Vì vậy, cần có chứng chỉ số để ràng buộc khóa công khai với danh tính đã được xác minh.

2.2. Hàm băm mật mã

Hàm băm mật mã nhận dữ liệu đầu vào có độ dài bất kỳ và sinh ra giá trị băm có độ dài cố định. Một hàm băm an toàn cần có các tính chất:

- Khó tìm dữ liệu đầu vào từ giá trị băm.
- Khó tìm hai dữ liệu khác nhau có cùng giá trị băm.
- Chỉ cần thay đổi nhỏ ở đầu vào thì giá trị băm thay đổi đáng kể.

Trong X.509, hàm băm thường được dùng cùng thuật toán ký số. Ví dụ: `sha256WithRSAEncryption` nghĩa là nội dung chứng chỉ được băm bằng SHA-256 rồi ký bằng RSA.

2.3. Chữ ký số

Chữ ký số giúp đảm bảo tính xác thực, toàn vẹn và chống chối bỏ. Trong chứng chỉ X.509, CA dùng khóa riêng để ký lên phần thông tin chứng chỉ. Bên kiểm tra dùng khóa công khai của CA để xác minh chữ ký. Nếu chữ ký hợp lệ, chứng chỉ chưa hết hạn, chưa bị thu hồi và phù hợp mục đích sử dụng thì chứng chỉ được xem là đáng tin cậy.

3. Tổng quan về X.509

X.509 là chuẩn định nghĩa định dạng chứng chỉ khóa công khai, danh sách thu hồi chứng chỉ và các cơ chế liên quan trong hạ tầng khóa công khai. Phiên bản được sử dụng phổ biến hiện nay là X.509 v3, cho phép mở rộng chứng chỉ bằng các trường extension như Subject Alternative Name, Key Usage, Extended Key Usage và Basic Constraints.

3.1. Vai trò của chứng chỉ X.509

Một chứng chỉ X.509 có vai trò như giấy tờ định danh điện tử. Nó cho biết:

- Chủ thể của chứng chỉ là ai.
- Khóa công khai nào thuộc về chủ thể đó.
- Tổ chức nào đã cấp và ký chứng chỉ.
- Chứng chỉ có hiệu lực trong khoảng thời gian nào.
- Chứng chỉ được phép dùng cho mục đích gì.

3.2. Các chủ thể trong PKI

Thành phần	Vai trò
CA gốc	Gốc tin cậy cao nhất, thường tự ký và được lưu trong kho tin cậy của hệ điều hành hoặc trình duyệt.
CA trung gian	Nhận chứng chỉ từ CA cấp cao hơn và dùng để ký chứng chỉ người dùng/máy chủ.
RA	Cơ quan đăng ký, có nhiệm vụ kiểm tra thông tin định danh trước khi CA cấp chứng chỉ.
Chủ thể	Cá nhân, máy chủ, tổ chức hoặc thiết bị được cấp chứng chỉ.
Bên phụ thuộc	Phần mềm hoặc người dùng kiểm tra chứng chỉ để quyết định có tin cậy hay không.

4. Cấu trúc chứng chỉ X.509 v3

Một chứng chỉ X.509 gồm ba phần chính: thông tin cần ký, thuật toán ký và chữ ký số.

4.1. Các trường cơ bản

Trường	Ý nghĩa
Version	Phiên bản chứng chỉ. X.509 v3 có giá trị version 3 nhưng trong mã hóa ASN.1 thường biểu diễn là số 2.

Serial Number	Số sê-ri duy nhất do CA cấp, dùng để phân biệt chứng chỉ và hỗ trợ thu hồi.
Signature Algorithm	Thuật toán được CA dùng để ký chứng chỉ.
Issuer	Tên định danh của CA phát hành chứng chỉ.
Validity	Khoảng thời gian chứng chỉ có hiệu lực, gồm Not Before và Not After.
Subject	Tên định danh của chủ thể được cấp chứng chỉ.
Subject Public Key Info	Khóa công khai của chủ thể và thuật toán tương ứng.
Extensions	Các mở rộng của X.509 v3, xác định ràng buộc và mục đích sử dụng.

4.2. Các extension quan trọng

4.2.1. Basic Constraints

Extension này cho biết chứng chỉ có được phép làm CA hay không. Với chứng chỉ CA, trường `CA:TRUE` phải được đặt. Với chứng chỉ máy chủ hoặc người dùng cuối, trường này thường là `CA:FALSE`. Đây là ràng buộc quan trọng để ngăn chứng chỉ máy chủ bị dùng trái phép để ký chứng chỉ khác.

4.2.2. Key Usage

Key Usage xác định các thao tác mật mã được phép dùng với khóa trong chứng chỉ, ví dụ:

- Digital Signature: dùng để ký số, thường dùng trong TLS.
- Key Encipherment: dùng để mã hóa khóa phiên, phổ biến với RSA trong TLS cũ.
- Certificate Sign: dùng cho chứng chỉ CA để ký chứng chỉ khác.
- CRL Sign: dùng cho CA để ký danh sách thu hồi chứng chỉ.

4.2.3. Extended Key Usage

Extended Key Usage mô tả mục đích sử dụng ở mức ứng dụng. Ví dụ:

- `serverAuth`: xác thực máy chủ TLS.
- `clientAuth`: xác thực máy khách TLS.
- `codeSigning`: ký mã nguồn hoặc phần mềm.
- `emailProtection`: bảo vệ email.

4.2.4. Subject Alternative Name

Subject Alternative Name, viết tắt là SAN, liệt kê các tên miền, địa chỉ IP hoặc định danh khác mà chứng chỉ đại diện. Trong hệ thống HTTPS hiện đại, trình duyệt ưu tiên SAN thay vì Common Name. Vì vậy, một chứng chỉ máy chủ nên khai báo SAN, ví dụ `DNS:example.com` và `DNS:www.example.com`.

5. Hạ tầng khóa công khai PKI

PKI là hệ thống gồm chính sách, phần mềm, phần cứng và con người dùng để quản lý vòng đời chứng chỉ số. Các hoạt động chính của PKI gồm:

- Sinh và bảo vệ khóa.
- Tiếp nhận yêu cầu cấp chứng chỉ.
- Xác minh danh tính chủ thể.
- Ký và phát hành chứng chỉ.
- Phân phối chứng chỉ và chuỗi CA.
- Thu hồi chứng chỉ khi khóa bị lộ hoặc thông tin không còn đúng.

5.1. Chuỗi tin cậy

Chuỗi tin cậy thường gồm chứng chỉ máy chủ, một hoặc nhiều CA trung gian và CA gốc. Bên kiểm tra sẽ xác minh từng chữ ký trong chuỗi, từ chứng chỉ máy chủ lên đến CA gốc đã được tin cậy sẵn.

Ví dụ chuỗi tin cậy:

`www.example.com → Intermediate CA → Root CA`

Nếu bất kỳ mắt xích nào trong chuỗi bị hết hạn, bị thu hồi, ký sai hoặc không phù hợp mục đích sử dụng, quá trình xác thực sẽ thất bại.

5.2. Quy trình cấp chứng chỉ

Quy trình cấp chứng chỉ thường gồm các bước:

1. Chủ thể tạo cặp khóa riêng/khóa công khai.
2. Chủ thể tạo CSR, trong đó chứa khóa công khai và thông tin định danh.
3. RA hoặc CA kiểm tra thông tin trong CSR.

4. CA ký chứng chỉ bằng khóa riêng của CA.
5. Chủ thể cài đặt chứng chỉ cùng chuỗi CA cần thiết.

5.3. Thu hồi chứng chỉ

Chứng chỉ cần bị thu hồi trước hạn trong các trường hợp:

- Khóa riêng bị lộ hoặc nghi ngờ bị lộ.
- Tên miền hoặc tổ chức không còn thuộc quyền kiểm soát của chủ thể.
- Thông tin trong chứng chỉ sai.
- Chủ thể vi phạm chính sách chứng thực.

Hai cơ chế kiểm tra thu hồi phổ biến là CRL và OCSP. CRL là danh sách chứng chỉ bị thu hồi do CA phát hành định kỳ. OCSP cho phép truy vấn trạng thái của một chứng chỉ cụ thể theo thời gian gần thực hơn.

6. X.509 trong giao thức TLS/HTTPS

Khi người dùng truy cập website HTTPS, trình duyệt và máy chủ thực hiện bắt tay TLS. Trong quá trình này, máy chủ gửi chứng chỉ X.509 cho trình duyệt. Trình duyệt kiểm tra:

- Tên miền truy cập có khớp với SAN trong chứng chỉ không.
- Chứng chỉ còn trong thời hạn hiệu lực không.
- Chữ ký chứng chỉ có hợp lệ không.
- Chuỗi CA có dẫn tới một CA gốc đáng tin cậy không.
- Chứng chỉ có bị thu hồi không.
- Extension Key Usage và Extended Key Usage có phù hợp với xác thực máy chủ không.

Sau khi xác thực thành công, TLS dùng các thuật toán trao đổi khóa để thiết lập khóa phiên đối xứng. Dữ liệu ứng dụng sau đó được mã hóa bằng khóa phiên, giúp đảm bảo tính bí mật và toàn vẹn.

7. Thực nghiệm với OpenSSL

Phần này minh họa việc xây dựng một CA đơn giản và cấp chứng chỉ máy chủ bằng OpenSSL. Các lệnh có thể chạy trên Linux, macOS hoặc Windows có cài OpenSSL.

7.1. Tạo khóa riêng cho Root CA

```
openssl genrsa -out rootCA.key 4096
```

Khóa `rootCA.key` là tài sản quan trọng nhất của CA. Trong môi trường thật, khóa này cần được bảo vệ bằng HSM hoặc ít nhất là mã hóa và lưu ngoại tuyến.

7.2. Tạo chứng chỉ tự ký cho Root CA

```
openssl req -x509 -new -nodes -key rootCA.key -sha256 -days 3650 \  
-out rootCA.crt \  
-subj "/C=VN/ST=HCM/L=HCM/O=Demo PKI/OU=Root CA/CN=Demo Root CA"
```

Chứng chỉ Root CA là chứng chỉ tự ký. Nó chỉ được tin cậy khi được cài đặt vào kho tin cậy của hệ điều hành, trình duyệt hoặc ứng dụng.

7.3. Tạo khóa riêng cho máy chủ

```
openssl genrsa -out server.key 2048
```

Trong môi trường thực tế, kích thước khóa RSA tối thiểu nên là 2048 bit. Với hệ thống mới, có thể cân nhắc ECDSA P-256 hoặc Ed25519 nếu nền tảng hỗ trợ.

7.4. Tạo file cấu hình SAN

```
[ req ]  
default_bits = 2048  
prompt = no  
default_md = sha256  
distinguished_name = dn  
req_extensions = req_ext  
  
[ dn ]  
C = VN  
ST = HCM  
L = HCM  
O = Demo Service
```

```
OU = Web
CN = x509-demo.local

[ req_ext ]
subjectAltName = @alt_names

[ alt_names ]
DNS.1 = x509-demo.local
DNS.2 = www.x509-demo.local
IP.1 = 127.0.0.1
```

7.5. Tạo CSR cho máy chủ

```
openssl req -new -key server.key -out server.csr -config server.cnf
```

CSR chứa khóa công khai và thông tin định danh của máy chủ. CSR không chứa khóa riêng.

7.6. Ký chứng chỉ máy chủ bằng Root CA

```
openssl x509 -req -in server.csr -CA rootCA.crt -CAkey rootCA.key \
  -CAcreateserial -out server.crt -days 825 -sha256 \
  -extensions req_ext -extfile server.cnf
```

Thời hạn 825 ngày là ví dụ thực nghiệm. Trong hệ sinh thái WebPKI công khai, thời hạn chứng chỉ máy chủ chịu ràng buộc bởi chính sách của trình duyệt và CA/B Forum, nên cần kiểm tra quy định hiện hành khi triển khai thật.

7.7. Kiểm tra nội dung chứng chỉ

```
openssl x509 -in server.crt -text -noout
```

Các trường cần chú ý gồm Issuer, Subject, Validity, Subject Public Key Info, X509v3 Basic Constraints, Key Usage, Extended Key Usage và Subject Alternative Name.

7.8. Kiểm tra chuỗi tin cậy

```
openssl verify -CAfile rootCA.crt server.crt
```

Nếu kết quả là `server.crt: OK`, chứng chỉ máy chủ đã được ký hợp lệ bởi CA được chỉ định.

8. Phân tích bảo mật

8.1. Rủi ro thường gặp

Rủi ro	Tác động	Biện pháp giảm thiểu
Lộ khóa riêng của CA	Kẻ tấn công có thể phát hành chứng chỉ giả	Lưu khóa trong HSM, giới hạn truy cập, dùng CA trung gian thay cho Root CA khi ký thường xuyên
Lộ khóa riêng máy chủ	Kẻ tấn công có thể giả mạo máy chủ hoặc giải mã lưu lượng trong một số cấu hình cũ	Thu hồi chứng chỉ, thay khóa, bật forward secrecy trong TLS
Chứng chỉ hết hạn	Dịch vụ bị trình duyệt hoặc client từ chối kết nối	Giám sát ngày hết hạn, tự động gia hạn
Thiếu SAN	Trình duyệt hiện đại không xác thực đúng tên miền	Luôn khai báo SAN khi cấp chứng chỉ TLS
Sai Key Usage	Chứng chỉ bị dùng sai mục đích hoặc bị client từ chối	Cấu hình extension theo đúng mục đích sử dụng
CA bị tin cậy quá rộng	Một CA nội bộ có thể cấp chứng chỉ cho nhiều hệ thống ngoài phạm vi cần thiết	Tách CA theo miền sử dụng, áp dụng name constraints nếu phù hợp

8.2. Nguyên tắc triển khai an toàn

- Root CA nên được lưu ngoại tuyến và chỉ dùng để ký CA trung gian.
- Khóa riêng phải được phân quyền chặt chẽ và mã hóa khi lưu trữ.
- Chứng chỉ máy chủ nên có thời hạn ngắn và được tự động gia hạn.
- Cần kiểm tra thu hồi chứng chỉ qua CRL hoặc OCSP.
- Không dùng thuật toán yếu như MD5, SHA-1, RSA 1024 bit.
- Luôn cấu hình SAN cho chứng chỉ TLS.
- Theo dõi nhật ký cấp chứng chỉ và cảnh báo khi có chứng chỉ bất thường.

9. Ứng dụng thực tế

9.1. HTTPS

HTTPS là ứng dụng phổ biến nhất của X.509. Chứng chỉ máy chủ giúp người dùng xác thực website và thiết lập kết nối TLS an toàn. Nếu thiếu X.509, người dùng không có cách đáng tin cậy để biết khóa công khai nhận được có thật sự thuộc về website cần truy cập hay không.

9.2. VPN và mạng nội bộ

Nhiều hệ thống VPN sử dụng chứng chỉ X.509 để xác thực máy khách và máy chủ. Trong mô hình này, doanh nghiệp có thể tự vận hành CA nội bộ để cấp chứng chỉ cho nhân viên hoặc thiết bị.

9.3. Chữ ký số và ký mã nguồn

Chứng chỉ X.509 cũng được dùng để ký tài liệu, email, phần mềm và container image. Việc ký giúp người nhận xác minh nguồn gốc và phát hiện thay đổi trái phép.

9.4. Thiết bị IoT

Trong IoT, mỗi thiết bị có thể được cấp một chứng chỉ riêng để định danh khi kết nối đến nền tảng quản lý. Cách này an toàn hơn so với việc dùng chung mật khẩu cho nhiều thiết bị.

10. So sánh CRL và OCSP

Tiêu chí	CRL	OCSP
Cách hoạt động	Tải danh sách chứng chỉ bị thu hồi	Truy vấn trạng thái một chứng chỉ cụ thể
Độ trễ cập nhật	Phụ thuộc chu kỳ phát hành CRL	Gần thời gian thực hơn
Băng thông	Có thể lớn nếu CRL dài	Nhỏ hơn vì chỉ hỏi từng chứng chỉ
Riêng tư	CA không biết chính xác người dùng đang kiểm tra website nào nếu CRL được cache	OCSP responder có thể thấy truy vấn trạng thái chứng chỉ

Ứng dụng	Phù hợp môi trường nội bộ, kiểm tra hàng loạt	Phù hợp kiểm tra trực tuyến từng chứng chỉ
----------	---	--

11. Hướng dẫn chạy hệ thống và video demo

Bên cạnh phần thực nghiệm bằng OpenSSL, nhóm đã đóng gói mã nguồn ứng dụng quản lý chứng chỉ X.509 trong file MHTT-CQ2026-17.zip. Phần này hướng dẫn giảng viên hoặc người chấm khởi chạy hệ thống demo từ source code đã nộp.

11.1. Chuẩn bị môi trường

Máy chạy demo cần cài Python 3 và có thể sử dụng terminal PowerShell trên Windows. Sau khi giải nén file mã nguồn, mở PowerShell tại thư mục project X509Certificate rồi cài dependency:

```
pip install -r requirements.txt
```

File `requirements.txt` chủ yếu dùng thư viện `cryptography`; các thành phần còn lại như `sqlite3`, `tkinter`, `hashlib` và HTTP server đều dùng thư viện chuẩn của Python.

11.2. Chạy ứng dụng chính

Từ thư mục source đã giải nén, chạy lệnh:

```
python main.py
```

Khi chạy lần đầu, ứng dụng sẽ tự tạo database, cấu hình mặc định, thư mục chứng chỉ runtime và tài khoản quản trị ban đầu. Nếu muốn dùng đúng trạng thái demo đã nộp, có thể copy các file trong thư mục dữ liệu `script`, `backup db`; 17 vào thư mục gốc của project trước khi chạy:

```
Copy-Item "script, backup db; 17\ca_app.db" .
Copy-Item "script, backup db; 17\master.key" .
Copy-Item "script, backup db; 17\certs" . -Recurse
```

11.3. Tài khoản đăng nhập và luồng kiểm thử nhanh

Tài khoản Admin mặc định:

Username	admin
Password	Admin@123

Luồng demo nhanh:

1. Đăng nhập Admin và kiểm tra hoặc sinh Root CA.
2. Đăng ký tài khoản Customer, sinh keypair RSA và tạo CSR cho domain demo.
3. Quay lại Admin để duyệt CSR và phát hành chứng chỉ X.509.
4. Customer xem hoặc tải chứng chỉ đã được cấp.
5. Thực hiện thu hồi chứng chỉ, publish CRL và kiểm tra trạng thái chứng chỉ.
6. Mở Verification Lab để minh họa các trường hợp valid, expired, revoked, tampered và renew.

11.4. Kiểm tra bằng test suite

Nếu cần kiểm chứng tự động các workflow chính, cài thêm `pytest` và chạy:

```
pip install pytest
python -m pytest --ignore=tests/test_scenarios.py
python tests\test_scenarios.py
```

11.5. Link video demo

Video demo được upload lên YouTube ở chế độ unlisted. Trước khi nộp Moodle chính thức, điền link vào dòng dưới đây:

YouTube demo link: <https://youtu.be/.....>

12. Kết quả đạt được

Qua quá trình nghiên cứu và thực nghiệm, đồ án đạt được các kết quả:

- Hiểu được vai trò của X.509 trong xác thực khóa công khai.
- Nắm được cấu trúc chứng chỉ X.509 v3 và ý nghĩa các trường quan trọng.
- Mô tả được cách PKI xây dựng chuỗi tin cậy từ Root CA đến chứng chỉ người dùng cuối.
- Thực hiện được quy trình tạo CA, tạo CSR, ký chứng chỉ và kiểm tra chứng chỉ bằng OpenSSL.
- Nhận diện được các rủi ro bảo mật phổ biến khi triển khai chứng chỉ số.

13. Hạn chế và hướng phát triển

Báo cáo và phần thực nghiệm mới dừng ở mô hình CA đơn giản. Trong hệ thống thực tế, cần nghiên cứu thêm:

- Mô hình Root CA ngoại tuyến và Intermediate CA trực tuyến.
- Tự động hóa cấp phát chứng chỉ bằng ACME.
- Triển khai OCSP responder và CRL distribution point.
- Tích hợp chứng chỉ với máy chủ web như Nginx, Apache hoặc IIS.
- Giám sát Certificate Transparency để phát hiện chứng chỉ cấp sai.

14. Kết luận

X.509 là một chuẩn quan trọng trong an toàn thông tin, đóng vai trò nền tảng cho xác thực danh tính và bảo vệ truyền thông trên Internet. Thông qua chứng chỉ số và hạ tầng PKI, các hệ thống có thể thiết lập niềm tin giữa các bên chưa từng trao đổi khóa trực tiếp. Tuy nhiên, mức độ an toàn của X.509 không chỉ phụ thuộc vào thuật toán mật mã mà còn phụ thuộc lớn vào quy trình vận hành CA, bảo vệ khóa riêng, cấu hình extension và cơ chế thu hồi chứng chỉ.

Việc hiểu rõ cấu trúc chứng chỉ, chuỗi tin cậy và các rủi ro triển khai giúp người quản trị xây dựng hệ thống bảo mật hơn, giảm nguy cơ giả mạo danh tính và tấn công trung gian.

Tài liệu tham khảo

1. ITU-T Recommendation X.509, Information technology - Open Systems Interconnection - The Directory: Public-key and attribute certificate frameworks.
2. IETF RFC 5280, Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List Profile.
3. OpenSSL Documentation, <https://www.openssl.org/docs/>.
4. Mozilla, CA Certificate Program and TLS recommendations.
5. CA/Browser Forum, Baseline Requirements for the Issuance and Management of Publicly-Trusted Certificates.